

Policy Nexus Compliance Audit Report

Automated GRC Contradiction & Compliance Analysis

Audit Parameter	Valuation / Posture Status
Audit Timestamp	7/12/2026, 10:44:39 AM
Audited Scope	2 core infrastructure & security policy documents
Overall Risk Index	68 / 100
Compliance Posture	ATTENTION REQUIRED

Document Status & Review Timelines

Document Name	Review Status	Last Reviewed	Next Review Date
Password Policy.md	OVERDUE	2021-08-15	2022-08-15
Cloud Identity Policy.md	WITHIN CYCLE	2026-01-10	2027-01-10

Executive Overview

High-priority password control discrepancies were detected between the general security policy guidelines and the cloud infrastructure team frameworks. Left unresolved, these contradictions create compliance gaps and security baseline variances across operational environments.

Detailed Contradiction Analysis

The compliance engine evaluated findings under the industry-standard 5 C's framework (Condition, Criteria, Cause, Consequence, Corrective Action) to structure resolution steps:

Finding 1: PASSWORD ROTATION REQUIREMENT CONFLICT (CRITICAL)

- 1. Condition:** *Password Policy.md §1.2* mandates periodic resets every 90 days. Conversely, *Cloud Identity Policy.md §2.2* states that password rotation is not required.
- 2. Criteria:** NIST SP 800-63B guidelines recommend deprecating forced periodic resets to prevent predictable password choices.
- 3. Cause:** Disconnected GRC review schedules between the general Security Committee and the Cloud Infrastructure Operations team.
- 4. Consequence:** User password fatigue, resulting in easily guessable credential patterns and increased security vulnerability.
- 5. Corrective Action:** Deprecate the 90-day rotation cycle in the general Password Policy and transition to passwordless multi-factor authentication (MFA).

Finding 2: INCONSISTENT PASSWORD COMPLEXITY MINIMUMS (MEDIUM)

- 1. Condition:** *Password Policy.md §1.1* requires passwords to be at least 12 characters. *Cloud Identity Policy.md §2.1* mandates a minimum of 14 characters.
- 2. Criteria:** Corporate security baselines mandate uniform complexity constraints across all active authentication directories.
- 3. Cause:** Separation of policy ownership; guidelines established independently by regional security teams.
- 4. Consequence:** Uneven security posture across cloud environments, leaving some directories susceptible to credential-cracking.
- 5. Corrective Action:** Harmonize the complexity threshold by enforcing the stronger 14-character minimum standard across all systems.

Strategic Corrective Action Plan

1. Standardize and unify credential policy guidelines globally across all operational teams.
2. Align the Password Policy rotation frequency directly with modern NIST guidelines (enforcing robust MFA protocols and avoiding arbitrary, time-based resets).

NIST SP 800-63B Guidelines Rationale: Modern security standards (NIST SP 800-63B) strongly recommend against forced password rotation cycles. Forcing users to change passwords arbitrarily (e.g. every 90 days) fosters 'user fatigue', leading to predictable password selections (e.g., adding sequential numbers or letters) which are easily cracked. Moving to phishing-resistant MFA reduces credential theft risks far more effectively than rotation controls while improving user productivity.

GRC Compliance Officer Signature

Date of Validation
